

Segregation-of-Duties Weakness Register

ID	Weakness / Conflict	Risk Created	Roles Involved	Recommended Control	Residual Risk / Review
1	IT Director owns security decisions, approves risks and manages implementation	Lack of independence and possible approval of self-created risks	IT Director, CISO, Executive Management	Establish independent CISO authority for security governance while IT remains responsible for implementation	Low residual risk after governance restructure; review annually
2	IT teams implement security controls without independent validation	Security weaknesses may remain undetected due to lack of assurance	IT, Security Team	Introduce security assurance reviews and control effectiveness testing	Moderate residual risk, review during security assessments
3	Business units make independent security decisions without central oversight	Inconsistent security practices across global offices	Business Units, CISO	Establish Business Security Champions and require governance committee oversight	Low residual risk after adoption; quarterly review
4	Technical teams accept risks without business owner approval	Business impact and risk appetite may not be considered	Business Owners, CRO	Require formal risk acceptance involving business owners, CRO and CISO	Low residual risk, monitor through risk register
5	Incident response decisions handled mainly by technical teams	Legal, regulatory and business consequences may be overlooked	IT, Security Operations, Legal, Executive Management	Establish cross functional incident response governance involving CISO, Legal, Risk and executives	Moderate residual risk, test through annual incident exercises

Decision-Recording and Assurance Note

TechGlobal should maintain a central Cyber Risk Decision Register to provide visibility and accountability for significant security decisions.

Each decision record should include:

- Unique reference number
- Decision creation date

- Summary of issue and potential impact
- Individual accountable for the risk
- Person or committee approving decision
- Available treatment approaches
- Approved action or risk acceptance outcome
- Risk assessments, reports and approvals
- Date for reassessment

Tracking and Review Process

1. Risk Identification
2. Assessment
3. Approval / Escalation
4. Monitoring
5. Closure
6. Audit Assurance
 - Internal Audit periodically reviews decision records to confirm:
 - Correct approval authority was used.
 - Risk ownership was assigned.
 - Evidence was maintained.
 - Actions were completed.

Assurance Principles

TechGlobal should ensure:

- Every significant cyber-risk decision has a named owner.
- Risk acceptance is approved at the appropriate authority level.
- Decisions are supported by documented evidence.
- Escalations follow predefined criteria rather than personal judgement.
- Closed risks remain available for future audits and lessons learned.